FADENA
FACULTAD DE DEFENSA NACIONAL

Universidad de la Defensa Nacional

Facultad de Defensa Nacional

Carrera: Lic. en Ciberdefensa

Materia
Sistemas Operativos II

Unidad 6 / Semana 13

Año: 2025

Contenidos

Firewalls. IDS/IPS. Seguridad en sistemas operativos: Gestión de usuarios y credenciales. Políticas de cuentas de usuario y contraseñas seguras. Administración de grupos de usuarios, roles y permisos.

Índice

1. Cortafuegos (Firewall) 3
1.1 Tipos de Firewalls 3
1.1.1 Firewall de Filtrado de Paquetes (Stateless) 3
1.1.2 Firewall de Inspección con Estado (Firewall Stateful Inspection) 4
Mecanismo de gestión de sesiones 5
1.1.3 Firewall a Nivel de Circuito (Circuit-level Gateway) 6
1.1.4 Firewall a Nivel de Aplicación (Application Level) - Proxy 8
Características: 8
1.1.5 Cortafuegos Personal (Host-Based Firewall) 9
Características: 9
2. Detección y prevención de intrusiones 10
2.1 Intrusion Detection System (IDS) 10
2.2 Intrusion Prevention System (IPS) 11
2.3 Resumen de diferencias entre IDS e IPS 12
2.4 Ejemplos actuales de IDS e IPS 13
3.Gestión de usuarios y grupos en sistemas operativos Linux 14
3.1 ¿Por qué es necesario trabajar con usuarios? 14
3.1.1 Principio de Mínimo Privilegio (seguridad) 14
3.1.2 Responsabilidad y auditoría (trazabilidad) 14
3.1.3 Estabilidad y personalización (Operativa) 14
3.2 Fundamentos del Usuario (user) 15
3.3 Clasificación de usuarios 15
3.3.1 Superusuario (Root) 16
3.3.2 Usuarios Normales (humanos o reales) 16
3.3.3 Usuarios de Sistema (servicio o lógicos) 16
3.4 Estructura de grupos (group) 17
Propósito del UPG 17
Ejemplo Práctico 17
3.5 Atributos de una cuenta de usuario 17
4. Políticas de cuentas de usuario y contraseñas seguras 18
4.1 Políticas de usuarios 18
4.2 Políticas de contraseñas 20
5. Roles y permisos 21
5.1 Modelos de Control de acceso 22
5.1.1 DAC: Control de Acceso Discrecional (Discretionary Access Control) 22
5.1.2 MAC: Control de Acceso Obligatorio (Mandatory Access Control) 22
5.1.3 RBAC: Control de Acceso Basado en Roles (Role-Based Access Control) 23

1. Cortafuegos (Firewall)

Un cortafuegos (firewall en inglés) es un sistema, ya sea de hardware o software, diseñado para controlar y filtrar el tráfico de red en una red de computadoras. Su función principal es aplicar las políticas de seguridad definidas por la organización, permitiendo o denegando las comunicaciones.

El cortafuegos se sitúa en el punto de conexión entre la red interna de la organización y la red externa, que suele ser Internet . Esta ubicación estratégica le permite actuar como una barrera de defensa, protegiendo la red interna de accesos no autorizados e intentos de explotación de posibles vulnerabilidades de sus sistemas.

1.1 Tipos de Firewalls

1.1.1 Firewall de Filtrado de Paquetes (Stateless)

Cortafuegos de capa de red o de filtrado de paquetes: Funciona a nivel de red como filtro de paquetes IP. A este nivel se pueden realizar filtros según los distintos campos de los paquetes IP: dirección IP origen, dirección IP destino. A menudo en este tipo de cortafuegos se permiten filtrados según campos de nivel de transporte, como el puerto origen y destino, o a nivel de enlace de datos como la dirección MAC.

Se definen reglas separadas para tráfico entrante y saliente.

Ejemplo de Funcionamiento de un Cortafuegos sin Estado (Stateless Firewall)

Considérese un cortafuegos que opera bajo un modelo sin estado (stateless), donde cada paquete de datos es evaluado de forma aislada, sin retener información sobre el contexto o el estado de las conexiones de red previas. Este mecanismo se asemeja a un filtro que examina los paquetes individualmente.

Análisis de la Conexión Bidireccional

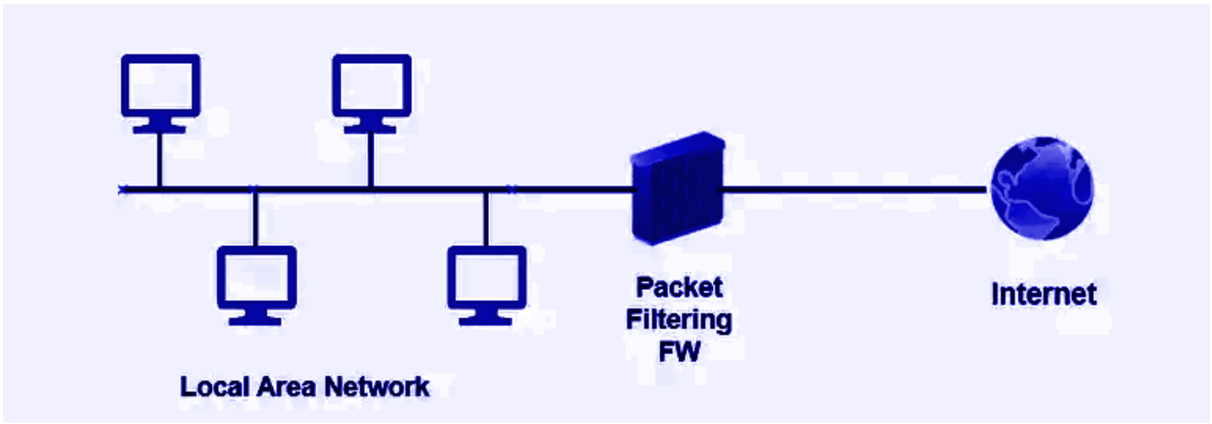
La limitación inherente a la arquitectura sin estado se manifiesta claramente durante el establecimiento de comunicaciones bidireccionales, como la solicitud de una página web:

1. Tráfico de Salida (Solicitud del Cliente):
    - Una máquina cliente interna (p. ej., IP 192.168.1.10) inicia una solicitud HTTP hacia un servidor externo (p. ej., IP 200.200.200.200).
    - El paquete de solicitud debe cumplir con una regla explícita de salida que autorice la comunicación del cliente a Internet a través del puerto 80 (HTTP).

2. Tráfico de Retorno (Respuesta del Servidor):
    - El paquete de respuesta del servidor externo, que contiene la página web solicitada, se dirige hacia la red interna.

- Debido a que el cortafuegos es “sin estado”, no mantiene la traza de la solicitud saliente original. Por lo tanto, el paquete de respuesta se interpreta como un nuevo tráfico entrante no solicitado.
- Para que la comunicación se complete satisfactoriamente, es indispensable que exista una segunda regla de entrada que permita específicamente el tráfico de respuesta desde la IP del servidor (200.200.200.200) hacia la IP del cliente (192.168.1.10). Si esta regla de entrada no está definida, el paquete será descartado, impidiendo la carga de la página web.

Este escenario subraya la ineficiencia y el requerimiento de reglas de filtrado doble en los sistemas sin estado, a diferencia de los cortafuegos con estado (stateful).



Esquema de un Firewall de Filtrado de Paquetes

1.1.2 Firewall de Inspección con Estado (Firewall Stateful Inspection)

Es un dispositivo de seguridad que no solo analiza los encabezados de los paquetes, sino que también mantiene un registro de todas las conexiones de red activas en una "tabla de estado". Esta tabla permite al firewall comprender el contexto y el estado de cada conexión (como el estado de una sesión TCP), lo que le permite tomar decisiones de filtrado más inteligentes y robustas al evaluar cada paquete en función de su relación con la conexión general, en lugar de analizar cada paquete de forma aislada.

Cómo funciona:

1. Mantenimiento de la tabla de estado: Cuando se inicia una conexión (por ejemplo, un intercambio de datos TCP), el firewall crea una entrada en su tabla de estado que registra detalles como las direcciones IP de origen y destino, los puertos y el estado de la conexión.
2. Análisis del tráfico: A medida que pasan más paquetes de esa conexión, el firewall actualiza la información en su tabla de estado.
3. Decisiones de filtrado: Las decisiones de permitir o denegar el tráfico se basan en el estado actual de la conexión, no solo en las reglas estáticas del

paquete individual. Por ejemplo, si un paquete de respuesta es esperado como parte de una conexión existente, el firewall lo permite; de lo contrario, puede ser bloqueado por ser sospechoso.

Ventajas de un firewall stateful:

- Mayor seguridad: Ofrece una seguridad más sólida al detectar patrones de tráfico sospechosos y actividades maliciosas que los firewalls de estado nulo (stateless) podrían pasar por alto.
- Detección de ataques más avanzada: Puede identificar y prevenir tipos de ataques como los de inundación de SYN o la inyección de paquetes, que no serían evidentes si solo se analiza cada paquete de forma individual.
- Filtrado de tráfico más preciso: Permite crear reglas más específicas y contextuales, lo que resulta en un control más granular del tráfico de red.

Desventajas:

- Mayor consumo de recursos: Requiere más potencia de procesamiento y memoria para mantener y actualizar la tabla de estado, lo que puede ralentizar ligeramente el tráfico en comparación con un firewall stateless.
- Mayor complejidad: Son más complejos de configurar y administrar debido a la gestión de las conexiones dinámicas.

Ejemplo de Funcionamiento de un Cortafuegos con Estado (*Stateful Firewall*)

Mecanismo de gestión de sesiones

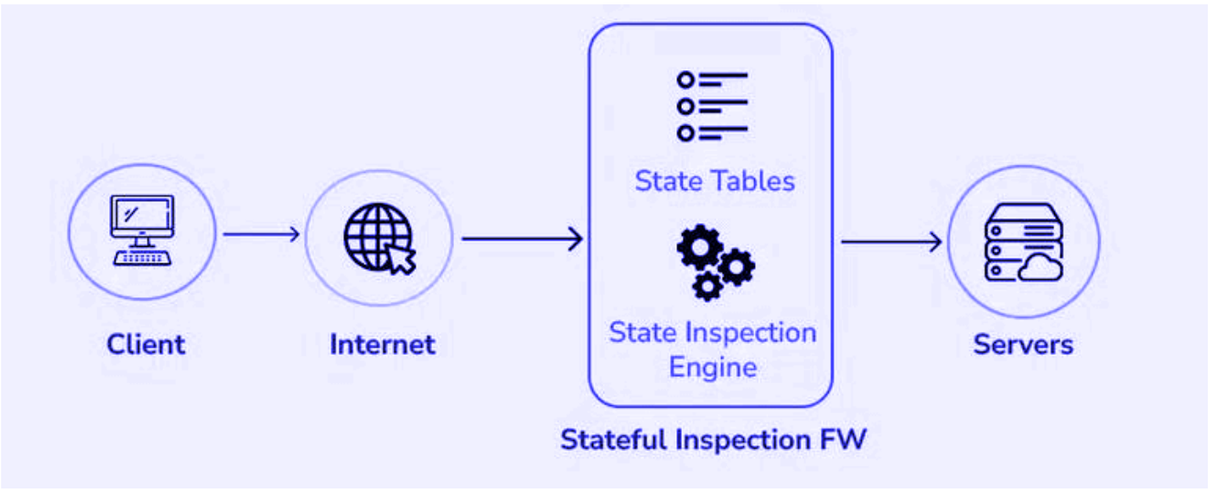
La **ventaja** fundamental de la arquitectura con estado reside en la capacidad de evaluar los paquetes de datos en función de su pertenencia a una sesión activa. Al iniciar una comunicación bidireccional, como la solicitud de un recurso web, el proceso es el siguiente:

1. **Registro de estado (Iniciación):**
    - Cuando la máquina cliente interna (p. ej., 192.168.1.10) envía una solicitud de conexión a un servidor externo, el cortafuegos **crea y registra una entrada de estado** en su tabla.
    - Dicha entrada contiene los parámetros clave de la sesión: dirección y puerto de origen (192.168.1.10:X), dirección y puerto de destino (200.200.200.200:80), y el protocolo utilizado (TCP).
2. **Validación del retorno (Respuesta):**
    - Cuando el paquete de respuesta del servidor externo arriba a la interfaz del cortafuegos, este no requiere de una regla de entrada explícita separada.

- El sistema **consulta la Tabla de Estados**. Si el paquete entrante coincide exactamente con una conexión registrada que fue iniciada desde la red interna y que se encuentra activa, el tráfico es **automáticamente validado y permitido**.

Este mecanismo asegura que solo las respuestas legítimas a solicitudes internas sean admitidas, **simplificando la configuración** y ofreciendo un nivel superior de **seguridad** en comparación con los cortafuegos sin estado.

En resumen, solo se necesita una regla de salida para que la conexión funcione. Esta capacidad de diferenciar el tráfico de respuesta del tráfico malicioso que se inicia desde afuera (que no tiene un estado registrado) es lo que lo hace mucho más seguro y eficiente.

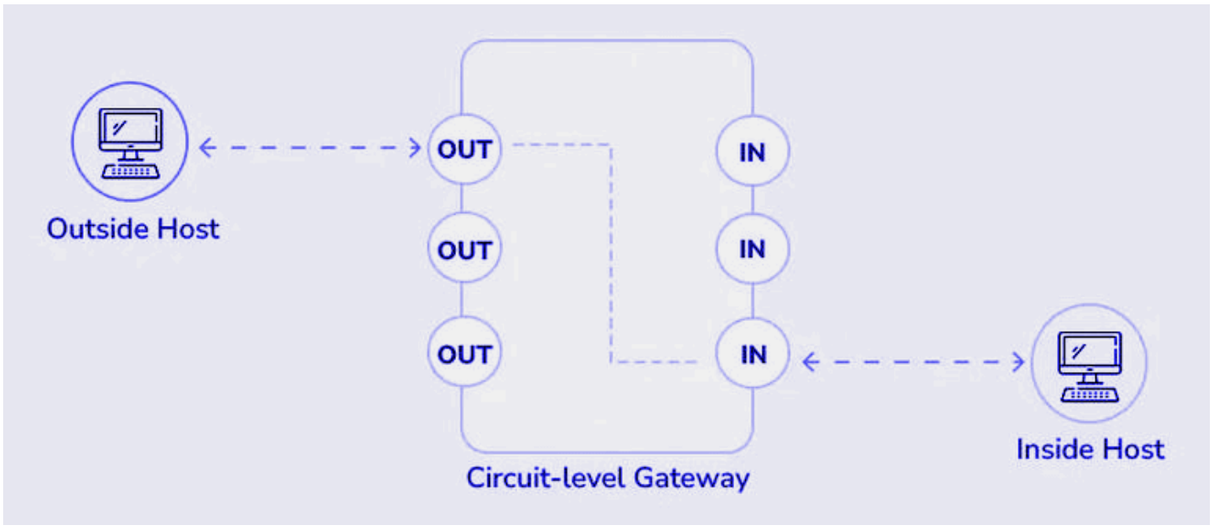


Esquema de un Firewall Stateful Inspection

1.1.3 Firewall a Nivel de Circuito (Circuit-level Gateway)

Este tipo de firewall actúa a nivel de capa de transporte. La seguridad se basa en el **establecimiento, seguimiento y liberación de la conexión**. Una vez que la conexión (el "circuito") se ha realizado correctamente el firewall **deja pasar los paquetes sin mayor inspección** de su contenido.

Es efectivo para validar la **integridad de la sesión**, pero resulta más vulnerable que un firewall *stateful* porque **no inspecciona el contenido** del paquete después de la validación inicial del circuito. Un atacante podría usar una conexión legítima para enviar datos maliciosos sin ser detectado.



Esquema de un Firewall a Nivel de Circuito

El diagrama muestra la comunicación entre un host interno y uno externo mediada por un **Circuit-Level Gateway**.

1. **Host Interno (Inside Host):**
   - Inicia una conexión con el **Host Externo**.
   - El tráfico de solicitud se dirige al Gateway, donde se procesa en la interfaz de **salida (OUT)**.
   - El cortafuegos valida el **establecimiento inicial de la sesión** aplicando mecanismos de seguridad básicos a nivel de protocolo de transporte.
2. **Circuit-Level Gateway:**
   - Actúa como **intermediario**, creando un **circuito virtual o túnel** entre los dos hosts.
   - Una vez que el cortafuegos verifica y **establece el circuito** entre un puerto **OUT** y su **IN** correspondiente, la conexión se considera segura a nivel de sesión.
   - Durante la vida útil de este circuito, los paquetes pueden fluir entre el origen y el destino con **control mínimo de seguridad adicional**, ya que la confianza se deposita en la validación inicial del establecimiento. El Gateway únicamente asegura el mantenimiento y la correcta liberación de la sesión.
3. **Host Externo (Outside Host):**
   - Representa la entidad externa con la que se comunica el host interno.
   - La respuesta del Host Externo ingresa al Gateway por el lado de la **entrada (IN)**.
   - Gracias al circuito previamente establecido, el tráfico de retorno es reconocido y dirigido al Host Interno sin necesidad de una inspección profunda del contenido del paquete.

En síntesis, el **Circuit-Level Gateway** se centra en la **gestión de sesiones en la capa de transporte**, estableciendo un "túnel de conexión" que, una vez validado

inicialmente, permite el flujo de tráfico con supervisión reducida sobre el contenido específico.

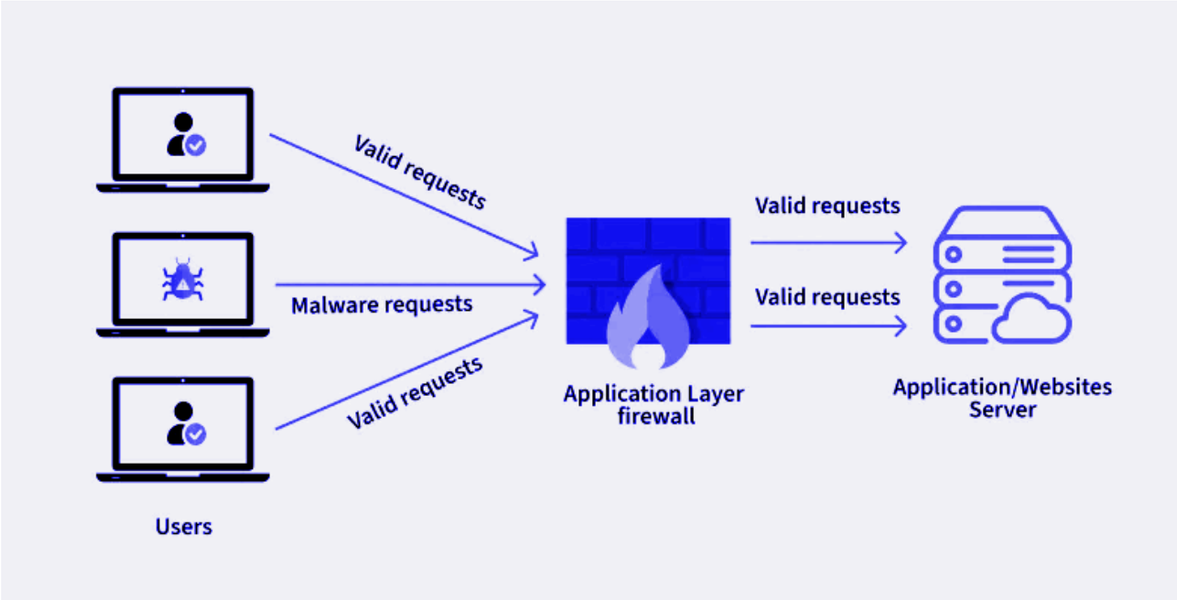
1.1.4 Firewall a Nivel de Aplicación (Application Level) - Proxy

El **cortafuegos a nivel de aplicación** (capa de aplicación) opera como un **servidor *proxy* (intermediario)**, inspeccionando y filtrando el tráfico basándose en el contenido de la aplicación y el protocolo específico que utiliza (como HTTP, FTP o SMTP). Se encarga de entender y filtrar las peticiones lógicas (como las de malware)

Características:

- **Inspección profunda:** A diferencia de otros tipos de firewall, inspecciona la carga útil (payload) del paquete para validar si las peticiones de la aplicación son legítimas, previniendo ataques específicos del protocolo.
- **Intermediario:** Rompe la conexión entre el cliente y el servidor. El cliente se conecta al proxy del firewall, y el firewall establece una nueva conexión con el servidor de destino. **Nunca hay una conexión directa** entre los hosts interno y externo.
- **Ocultamiento de IP:** Oculta las direcciones IP de la red interna al mundo exterior, ya que todo el tráfico parece originarse desde el proxy del firewall.

Si bien este tipo de firewall garantiza una **seguridad superior** mediante la **inspección del tráfico a nivel de aplicación**, esta misma profundidad de análisis es el factor que potencialmente **incrementa la latencia** (retraso) en las comunicaciones.



Esquema de un Firewall a Nivel de Aplicación (ejemplo de Proxy)

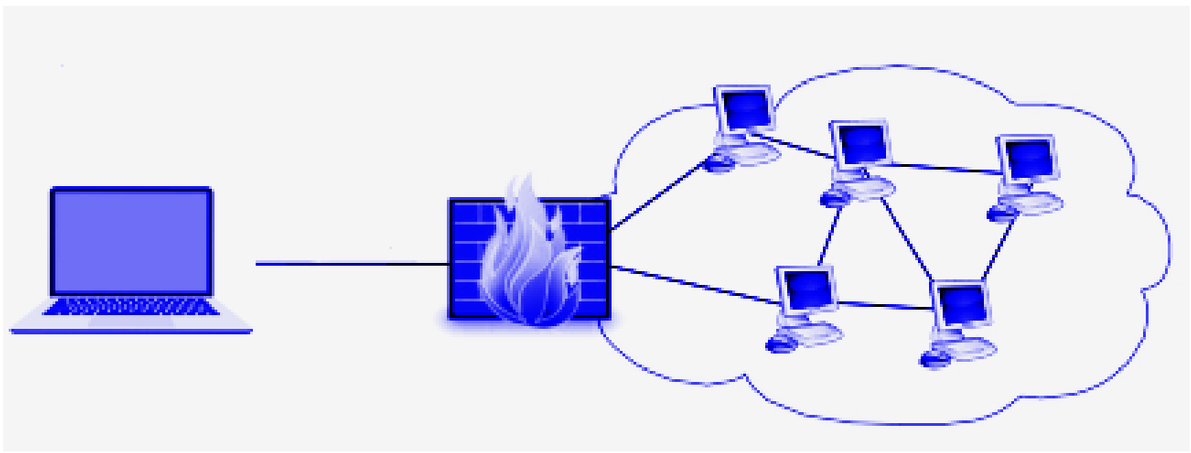
La función central del *proxy* (del latín *proximus*, que implica "actuar en lugar de") es **interceptar la conexión inicial**. El *proxy* **examina a fondo la petición** y, de forma crucial, **termina la conexión** iniciada por el cliente. Si la solicitud es validada según la política de seguridad, el *firewall* **establece una nueva conexión legítima** con el servidor de destino, actuando como un intermediario completo en la transferencia de datos.

1.1.5 Cortafuegos Personal (Host-Based Firewall)

Un **cortafuegos personal** es una aplicación de *software* instalada directamente en el sistema operativo (*host*) de un dispositivo final (como una computadora o servidor), a diferencia de los *firewalls* de red que protegen perímetros completos.

Características:

- **Nivel de sistema operativo (SO):** Opera a nivel del *host*, controlando el tráfico que entra y sale de **un único dispositivo**.
- **Inspección local:** Aplica reglas de filtrado específicas del usuario o del sistema, decidiendo qué programas o procesos en la máquina tienen permitido establecer conexiones entrantes o salientes.
- **Función complementaria:** Es fundamental para la seguridad en entornos móviles o remotos, ya que protege el dispositivo incluso cuando este no se encuentra detrás del *firewall* perimetral de la organización. A menudo, complementa la protección de los firewalls de red.
- **Ejemplos:** El Firewall de Windows Defender o iptables en sistemas Linux son ejemplos comunes de esta categoría.



Esquema de un Firewall Personal (Host-Based Firewall)

2. Detección y prevención de intrusiones

En el diseño de arquitecturas modernas seguras, la seguridad perimetral constituye la primera línea de defensa frente a amenazas externas. Como hemos visto, tradicionalmente, esta capa se ha basado en el uso de firewalls.

Sin embargo, el creciente nivel de sofisticación de los ataques, junto con la expansión de servicios expuestos a Internet, ha evidenciado la necesidad de incorporar mecanismos más dinámicos y contextuales.

En este escenario, los **sistemas de detección** (IDS) y **prevención de intrusiones** (IPS) se integran como componentes indispensables para fortalecer la seguridad del perímetro.

Mientras que el IDS permite identificar patrones sospechosos y generar alertas ante posibles intentos de intrusión, el IPS actúa de forma activa para bloquear o mitigar dichos intentos en tiempo real. Ambos sistemas complementan las funciones del firewall, aportando visibilidad más profunda, análisis de comportamiento y capacidad de respuesta ante amenazas que podrían evadir controles tradicionales.

La combinación de firewalls avanzados (NGFW), IDS/IPS y plataformas de correlación de eventos (SIEM) permite construir perímetros inteligentes, capaces de adaptarse a entornos híbridos (on-premise, cloud, dispositivos móviles etc), segmentar riesgos y responder de manera automatizada ante incidentes.

Esta evolución transforma la *seguridad perimetral* en un ecosistema dinámico, donde la detección y la prevención no son funciones aisladas, sino parte de una estrategia integral de protección.

2.1 Intrusion Detection System (IDS)

Un *Sistema de Detección de Intrusos* (IDS, por sus siglas en inglés) es una solución de seguridad informática —ya sea en forma de dispositivo o software— cuya **función principal consiste en monitorear el tráfico de red o la actividad de los sistemas anfitriones (hosts)** con el objetivo de identificar patrones sospechosos o comportamientos maliciosos que puedan indicar intentos de intrusión, vulneración o ataque.

Una característica distintiva del IDS es su *naturaleza pasiva*: no interviene directamente en el flujo de datos ni bloquea el tráfico, sino que se limita a generar alertas, registrar eventos y notificar al administrador para que se tomen las medidas correspondientes.

Clasificación

Los IDS se clasifican comúnmente según el ámbito que supervisan:

NIDS (Network-based IDS):

Monitorea todo el tráfico de red que pasa por un segmento específico. Se coloca en un punto estratégico (como un puerto SPAN o mirror de un switch) donde puede "escuchar" una copia del tráfico, sin estar directamente en la ruta de los datos.

Ventaja: Proporciona una visión amplia de la actividad en la red.

Desventaja: Puede tener problemas para inspeccionar tráfico cifrado y puede generar un gran volumen de datos (logs) difíciles de analizar.

HIDS (Host-based IDS):

Se instala directamente en un dispositivo específico (servidor, endpoint) y monitorea la actividad interna. Vigila archivos de registro (logs), llamadas al sistema, modificaciones en archivos críticos del sistema operativo, cambios en el registro (registry en Windows), y actividad de usuarios.

Ventaja: Detecta ataques que ya han superado el perímetro de la red o aquellos que se originan internamente.

Desventaja: Consume recursos del host y solo ofrece visibilidad del dispositivo donde está instalado.

2.2 Intrusion Prevention System (IPS)

El IPS es una evolución del IDS. Comparte la función de ***detección***, pero su rol más importante es la **prevención activa y en tiempo real**.

La característica clave del IPS es que es un sistema activo que se coloca en línea, lo que significa que todo el tráfico de red debe pasar a través de él. Esto le da la capacidad de tomar medidas inmediatas.

Modos de Operación y Acción

El IPS realiza las mismas inspecciones que un IDS, pero sus acciones son la principal diferencia:

- **Análisis y Detección:** Al igual que el IDS, utiliza firmas, análisis de protocolos y detección de anomalías para identificar amenazas.
- **Prevención Activa:** Cuando se detecta una amenaza, el IPS toma una de las siguientes acciones:
    - **Bloqueo de Tráfico**: Detiene y elimina los paquetes de datos maliciosos antes de que lleguen a su destino.

- **Reinicio de Conexión:** Cierra o resetea la conexión (enviando paquetes TCP RST) entre el atacante y la víctima.
- **Cuarentena/Bloqueo de IP:** Agrega la dirección IP de origen a una lista de bloqueo temporal o permanente, o incluso puede enviar una actualización al firewall para que bloquee ese origen a nivel de red.
- **Engaño:** Algunos sistemas avanzados intentan engañar al atacante para que se conecte a un sistema señuelo (honeypot).

Riesgos del IPS

Debido a que el IPS está en la ruta crítica del tráfico, presenta un riesgo inherente:

- **Falsos Positivos:** Si el IPS identifica erróneamente el tráfico legítimo como una amenaza (un falso positivo), lo bloqueará o lo interrumpirá, causando una denegación de servicio no deseada (DoS) para los usuarios o sistemas legítimos.
- **Latencia:** El proceso de inspección profunda de paquetes (DPI) puede introducir una pequeña demora (latencia) en el tráfico de red, por lo que los sistemas IPS deben ser soluciones de hardware y software de muy alto rendimiento.

2.3 Resumen de diferencias entre IDS e IPS

Característica	IDS (Detección)	IPS (Prevención)
Naturaleza	Pasiva	Activa
Acción ante amenaza	Alerta	Bloquea / mitiga
Ubicación	Fuera de línea / Port mirroring	En línea
Tiempo de respuesta	Manual	Automático

2.4 Ejemplos actuales de IDS e IPS

Tipo	Herramienta	Clasificación	Características destacadas
IDS	Snort	NIDS	Basado en firmas, código abierto, ampliamente usado en redes corporativas.
IDS	Suricata	NIDS/HIDS	Multihilo, DPI, compatible con reglas de Snort, detección avanzada.
IDS	Zeek (Bro)	NIDS	Análisis contextual, scripting personalizado, ideal para investigación forense.
IDS	OSSEC	HIDS	Monitoreo de logs, integridad de archivos, alertas en tiempo real.
IPS	Cisco Firepower	IPS/NGFW	Prevención avanzada, integración con SecureX, visibilidad completa.
IPS	Fortinet FortiIPS	IPS dedicado	Alta velocidad, protección contra exploits, integración con FortiGate.
IPS	Palo Alto Threat Prevention	IPS integrado	Prevención de amenazas en tiempo real, análisis de comportamiento.
IPS	Trend Micro TippingPoint	IPS dedicado	Protección contra vulnerabilidades conocidas y desconocidas.

3.Gestión de usuarios y grupos en sistemas operativos Linux

La correcta administración de usuarios y grupos es un pilar fundamental para la seguridad y la asignación de permisos en cualquier sistema Linux.

3.1 ¿Por qué es necesario trabajar con usuarios?

La implementación de múltiples cuentas de usuario en un sistema operativo no es una característica opcional, sino un requisito esencial que satisface tres necesidades fundamentales: seguridad, responsabilidad (auditoría) y estabilidad operativa.

3.1.1 Principio de Mínimo Privilegio (seguridad)

La necesidad más crítica es la seguridad. Al crear cuentas de usuario estándar, se aplica automáticamente el Principio de Mínimo Privilegio (PoLP). Este principio asegura que cada persona o servicio sólo disponga de los permisos estrictamente necesarios para realizar sus tareas.

- Protección del sistema: Impide que un error, un *script* malicioso o una aplicación defectuosa ejecutada por un usuario común pueda modificar, eliminar o dañar archivos esenciales del sistema operativo (que son propiedad del usuario **root**).
- Aislamiento de aplicaciones: Permite que las aplicaciones y servicios críticos (como servidores web o bases de datos) se ejecuten con un usuario lógico dedicado con permisos muy limitados. Si ese servicio es atacado, el atacante solo obtiene acceso a los recursos de ese usuario, y no al control total del sistema.

3.1.2 Responsabilidad y auditoría (trazabilidad)

Cuando varias personas o servicios comparten un sistema, las cuentas individuales permiten la trazabilidad de acciones. Si un archivo es modificado o se produce un fallo, el sistema puede identificar exactamente:

- Quién realizó la acción (el usuario logueado).
- Qué acción se tomó.
- Cuándo ocurrió.

Esta capacidad de auditoría es vital para el cumplimiento normativo y para la resolución eficiente de problemas (debugging).

3.1.3 Estabilidad y personalización (Operativa)

Cada usuario tiene su propio espacio de trabajo aislado, garantizando que:

- Aislamiento de entornos: Las configuraciones y personalizaciones de un

usuario (como variables de entorno) no interfieran con las de otros usuarios ni con la configuración global del sistema.

- Protección de datos: Los usuarios solo pueden acceder y modificar los archivos almacenados en sus propios directorios personales o aquellos recursos explícitamente compartidos a través de un grupo.

3.2 Fundamentos del Usuario (user)

Un **usuario** en Linux representa tanto a una persona física (usuario real) como a una entidad no humana dedicada a la gestión de servicios o aplicaciones (usuario lógico).

Cada cuenta de usuario se define mediante los siguientes elementos:

- **Identificador Único (UID):** Un número exclusivo que el sistema utiliza internamente para identificar al usuario, independientemente de su nombre de cuenta.
- **Restricciones de seguridad:** Los usuarios estándar operan bajo estrictas limitaciones de privilegios. Estas restricciones impiden la ejecución de comandos que puedan comprometer la integridad del sistema, modificar la configuración esencial o afectar servicios críticos en segundo plano.
- **Directorio personal:** Una zona reservada en el disco (home directory) para el almacenamiento de datos y la personalización del entorno de trabajo.



Material complementario

La actividad obligatoria que deberán realizar en esta unidad se centra en la gestión de usuarios y grupos en Ubuntu Linux. Para realizar la actividad deberán ingresar con el usuario y clave que hayan creado al instalar el sistema operativo.

Quienes no recuerden cómo trabajar con la terminal de Linux y con la shell, que en el caso de Ubuntu es BASH (Bourne Again Shell).

Les ayudará ver el siguiente video como repaso. Haga clic **aquí**.

3.3 Clasificación de usuarios

La clasificación básica de usuarios en Linux se basa generalmente en su **propósito** y sus **privilegios**. Los usuarios de sistema se sitúan en el grupo de cuentas funcionales y no humanas:

3.3.1 Superusuario (Root)

- **Identificador (UID):** Siempre es **0**.
- **Propósito:** Es la cuenta administrativa con **máximos privilegios** sobre todo el sistema operativo. Puede acceder, modificar o eliminar cualquier archivo y ejecutar cualquier comando.
- **Clasificación:** Es una cuenta especial y única que, aunque puede ser usada por una persona (el administrador), funcionalmente es el **controlador maestro** del sistema.

3.3.2 Usuarios Normales (humanos o reales)

- **Identificador (UID):** Generalmente **mayor o igual a 1000** (depende de la distribución, pero es el estándar moderno).
- **Propósito:** Son las cuentas asignadas a **personas físicas** que inician sesión de forma interactiva (a través de la terminal o una interfaz gráfica).
- **Clasificación:** Cuentas con privilegios limitados a su **directorio personal** (/home/nombre_usuario) y que requieren la elevación de permisos (ej. sudo) para realizar tareas administrativas.

3.3.3 Usuarios de Sistema (servicio o lógicos)

- **Identificador (UID):** Generalmente **entre 1 y 999** (también puede variar, pero están en el rango inferior).
- **Propósito:** Su función es **ejecutar servicios y procesos** en segundo plano (daemons) con el **mínimo de privilegios** necesarios. Esto es crucial para la seguridad: si el servidor web (www-data) fuera comprometido, el atacante solo obtendría acceso a los archivos que ese usuario puede ver, no a todo el sistema.
- **Clasificación:** Son cuentas **no interactivas**. No se utilizan para iniciar sesión, sino únicamente para la **propiedad y ejecución** de archivos y procesos asociados a un *soft*ware (ej. apache, mysql, postfix).

Tipo de Usuario	Rango Típico de UID	Interactivo	Función Principal
Superusuario (root)	0	Sí (Administrador)	Control total del sistema.
Usuarios de Sistema	1 - 999	No	Ejecución segura de servicios.
Usuarios Normales	≥1000	Sí (Usuario)	Trabajo diario y gestión de archivos personales.

3.4 Estructura de grupos (group)

Un **grupo** es una construcción lógica diseñada para simplificar la administración de permisos. Permite agrupar múltiples cuentas de usuario con un propósito común y aplicarles, de forma colectiva, los mismos derechos de acceso a determinados recursos (archivos, directorios o dispositivos).

Cada usuario tiene un **grupo primario** y puede pertenecer a múltiples **grupos secundarios**.

El grupo primario por defecto que tendrá un usuario en Linux, cuando no se especifica explícitamente otro, generalmente es un **grupo que lleva el mismo nombre que su cuenta de usuario.**

A esta práctica se la conoce como **"User Private Group" (UPG)** o **Grupo Privado de Usuario**.

Propósito del UPG

El objetivo de que cada usuario tenga su propio grupo primario es de **seguridad y aislamiento**. Garantiza que, por defecto, los archivos y directorios creados por ese usuario *pmartinez* sean accesibles sólo por él mismo (dueño) y por el grupo primario *pmartinez* (al cual sólo él pertenece), a menos que se modifiquen los permisos o el usuario sea añadido a otros grupos secundarios.

Ejemplo Práctico

Si usted crea un usuario llamado ***pmartinez*** con el comando:

useradd -m pmartinez

1. Se crea la cuenta de usuario: *pmartinez*
2. Se crea un grupo primario con el mismo nombre: *pmartinez*
3. El usuario *pmartinez* es automáticamente el **único miembro** de ese grupo primario *pmartinez*.

- **Identificador Único de Grupo (GID):** Al igual que los usuarios, cada grupo está identificado por un nombre y un **GID** único.
- **Pertenencia obligatoria:** Toda cuenta de usuario debe pertenecer al menos a un grupo, conocido como su **grupo primario**. Adicionalmente, un usuario puede ser miembro de múltiples **grupos secundarios (o suplementarios)**.

3.5 Atributos de una cuenta de usuario

Una cuenta de usuario está definida por múltiples características esenciales que controlan su entorno, seguridad y límites dentro del sistema:

Característica	Descripción Detallada
Identificación	Nombre de cuenta y UID únicos en el sistema.
Pertenencia a Grupos	Asociación con un grupo primario obligatorio y membresía opcional a grupos secundarios.
Intérprete de Comandos	Shell asociado a la cuenta (p. ej., bash) que le permite ejecutar comandos y utilidades.
Seguridad	Exigencia de una contraseña robusta, con la posibilidad de incluir una fecha de caducidad para la cuenta.
Entorno Personalizado	Definición de un perfil de entrada (login profile) que establece las características iniciales de su sesión (variables de entorno, aliases, etc.).
Cuotas de Disco	Posibilidad de asignar límites de espacio de almacenamiento por usuario en sistemas de archivos específicos.
Auditoría	Habilitación de sistemas que registran las actividades del usuario con fines de control y cumplimiento.

Actividad S13-A1



Realice la actividad identificada como *S13-A1* (Semana 13, Actividad 1) en la sección de actividades del campus.

4. Políticas de cuentas de usuario y contraseñas seguras

La **gestión de identidades** (Identity Management) forma parte de las políticas de seguridad de una organización. En este marco, es necesario definir con claridad las características que deben cumplir tanto los usuarios como las contraseñas dentro de los entornos digitales. Estas definiciones incluyen criterios de creación, autenticación, permisos y vigencia, y deben ser configuradas e implementadas en cada plataforma tecnológica según sus capacidades y requerimientos específicos

4.1 Políticas de usuarios

Es el conjunto de reglas que definen cómo se crean, gestionan y supervisan las cuentas de usuario en un sistema operativo. Los *usuarios* permiten identificar a una persona real / servicio que utiliza los sistemas informáticos de la organización.

Definen entre otras cosas, pero no se limitan a estos:

- El proceso de creación de los usuarios, quienes pueden lo solicitan y quienes lo crean / eliminan
- La creación, modificación y baja de usuarios debe realizarse bajos los requisitos y controles definidos y en tiempos apropiados
- Formato del usuario (nombres y apellidos / siglas / Nros / otros)
- Dónde están almacenados, si en entornos locales o globales (nube) si son organizaciones de múltiples sitios
- Tecnología que se utilizará (AD, OpenLDAP, Apache Directory, Okta, Google Cloud Identity, etc)
- Grupos *principal* y *secundarios* que se usarán
- Criterios de expiración del usuario
- Estados de la cuenta (usuario) activa, bloqueada, expirada, inactiva)

Las normas ISO/IEC 27001 y 27002 abordan la gestión de usuarios dentro del dominio de control de acceso (A.9). En particular, la ISO/IEC 27002 detalla los siguientes controles clave:

- **Registro de usuarios:**
  Todo usuario debe ser registrado formalmente antes de otorgarle acceso.

- **Gestión de acceso:**
  Los derechos de acceso deben asignarse según el rol y necesidades del usuario.

- **Acceso privilegiado**
  Los privilegios especiales deben ser gestionados con controles adicionales.

- **Autenticación secreta**
  Las credenciales (como contraseñas) deben ser protegidas y gestionadas de forma segura.

- **Revisión de accesos**
  Los derechos de acceso deben revisarse periódicamente.

- **Eliminación de accesos**
  Los accesos deben ser revocados inmediatamente cuando el usuario ya no los necesita.

En la práctica, esto implica:

- **Alta controlada:** los usuarios no deben crearse de forma manual o informal.
- **Asignación por rol:** cada usuario debe tener solo los permisos necesarios para su función.

- **Auditoría continua:** los accesos deben ser revisados y ajustados regularmente.
- **Seguridad de credenciales:** las contraseñas y métodos de autenticación deben cumplir políticas robustas.
- **Desactivación inmediata:** al finalizar la relación laboral o cambiar de rol, los accesos deben eliminarse sin demora.

4.2 Políticas de contraseñas

Las contraseñas son el mecanismo tradicional de autenticación que permiten verificar la identidad de un usuario antes de concederle acceso a sistemas, servicios o información (*Ver Autenticación*). Funcionan como una clave secreta que debe ser conocida únicamente por el usuario autorizado y le permite el acceso a los sistemas informáticos.

Desde el punto de vista de la seguridad informática, las contraseñas son uno de los primeros controles de acceso y, por tanto, una barrera crítica frente a accesos no autorizados, suplantación de identidad y robo de información.

Funciones de las contraseñas en la seguridad

- Autenticación: confirman que el usuario es quien dice ser.
- Control de acceso: permiten o restringen el uso de recursos según el perfil del usuario.
- Trazabilidad: vinculan acciones y eventos a identidades verificadas.
- Prevención de intrusiones: dificultan el acceso externo sin credenciales válidas.

La familia de normas ISO/IEC 27000, especialmente la 27001 (gestión de seguridad de la información) y la 27002 (controles de seguridad), establece directrices claras sobre el uso y gestión de contraseñas como parte de los controles de acceso (dominio A.9).

Recomendaciones según ISO/IEC 27002

Estas son las buenas prácticas alineadas con la mencionada norma.

- Longitud mínima recomendada: 12 caracteres.
- Uso de caracteres alfanuméricos y símbolos.
- Evitar uso de contraseñas que se puedan adivinar fácilmente, como fechas, nombres, etc.

- Los usuarios deben ser obligados a mantener la confidencialidad y no compartirla y a cambiarla ante cualquier sospecha de haber sido comprometida
- Cambios forzados: periódicos, en frecuencia definida y en el primer uso de contraseñas temporales o iniciales.
- No reutilización de contraseñas anteriores
- Bloqueo de cuenta tras múltiples intentos fallidos.
- Almacenamiento cifrado y acceso restringido a las credenciales.

Recomienda además la implementación de MFA (autenticación multifactor)

5. Roles y permisos

La gestión de Roles y Permisos (o derechos de acceso) es la implementación práctica del control de acceso en un sistema operativo o aplicación.

Una vez que un usuario ha sido autenticado (verificado con su contraseña), estos conceptos determinan su autorización, es decir, qué acciones el usuario ya autenticado puede realizar.

Conceptos fundamentales

Término	Definición en Sistemas Operativos	Ejemplo
Recurso (Asset)	Cualquier objeto o dato que el sistema debe proteger.	Archivo (documento.pdf), Directorio (/etc/), Dispositivo (impresora)
Permiso (Right)	La capacidad de realizar una acción específica sobre un recurso.	**Leer** (r), **Escribir** (w), **Ejecutar** (x), **Modificar**, **Eliminar**.
Identidad (User)	La entidad que busca acceder al recurso (persona o servicio).	El usuario "jlopez" o el servicio "apache".

Rol (Role)	Un conjunto predefinido de permisos o responsabilidades que se aplica a múltiples usuarios.	Usuario estándar Administrador Invitado Usuario de ventas

5.1 Modelos de Control de acceso

5.1.1 DAC: Control de Acceso Discrecional (Discretionary Access Control)

El modelo DAC es el más flexible y común, utilizado en la configuración predeterminada de la mayoría de los sistemas operativos (ej. Linux/Unix y Windows NTFS).

- **¿Quién controla?** El **propietario** del recurso.
- **Mecanismo:** El propietario (o un administrador) tiene la autoridad para crear, modificar o revocar los permisos de su propio recurso, a su "discreción".
- **Implementación Técnica:**
  - **Linux/Unix:** Se usa la tríada **u-g-o** (Usuario, Grupo, Otros) y los permisos **rwx** (Lectura, Escritura, Ejecución). El comando chmod permite al propietario cambiar los permisos.
  - **Windows NTFS:** Utiliza **Listas de Control de Acceso (ACLs)**, donde el propietario puede añadir o eliminar usuarios o grupos de la lista y especificar sus derechos.

Riesgo: Un alto riesgo de seguridad porque la seguridad **depende de las decisiones individuales** de los usuarios. Un usuario que cometa un error al asignar permisos puede exponer un recurso valioso.

5.1.2 MAC: Control de Acceso Obligatorio (Mandatory Access Control)

El modelo MAC es el más estricto y se utiliza en entornos de alta seguridad donde los errores humanos no son aceptables (ej. militar, gubernamental, o sistemas especializados como SELinux/AppArmor en Linux).

- **¿Quién controla?** El **administrador central** (o el SO).
- **Mecanismo:** Se asignan **etiquetas de seguridad** (niveles de clasificación) tanto a los **recursos** (ej., "Secreto," "Confidencial") como a las **identidades** (ej., "Nivel 5," "Nivel 3"). Las reglas de acceso son inmodificables por el

usuario. Un usuario solo puede acceder a un recurso si su etiqueta es igual o superior a la del recurso.

- **Implementación Técnica:** El SO verifica la coincidencia de las etiquetas de seguridad antes de permitir el acceso, **ignorando** cualquier configuración DAC que el usuario haya intentado establecer.

Ventaja: Máxima seguridad y cumplimiento del **PoLP**[1], ya que el acceso no puede ser flexibilizado por los usuarios finales.

Desventaja: La rigidez del sistema

5.1.3 RBAC: Control de Acceso Basado en Roles (Role-Based Access Control)

El modelo RBAC es el más común y recomendado en grandes entornos empresariales por su **escalabilidad y facilidad de gestión**, siendo el estándar de facto para cumplir con la **ISO 27001**.

- **¿Quién controla?** Los **Roles**, definidos por el administrador.
- **Mecanismo:**
  1. Se define un **Rol** (ej., "Contador," "Gerente de Proyecto").
  2. Se asignan los **Permisos** necesarios a ese Rol (siguiendo el PoLP).
  3. Se asignan **Cuentas de Usuario** a uno o varios Roles.
- **Implementación Técnica:** En Windows, esto se implementa mediante la asignación de usuarios a **Grupos de Seguridad** (el grupo actúa como el rol). En sistemas de gestión de identidad (como Active Directory o LDAP), el proceso es altamente centralizado.

Ventaja: Simplifica la gestión. En lugar de asignar 50 permisos a 100 usuarios (5000 operaciones), se asignan 50 permisos a 5 Roles, y luego se asignan 100 usuarios a esos 5 Roles.

Resumen

Característica	DAC	MAC	RBAC
Poder de Decisión	Propietario del Recurso	Administrador Central/SO	Rol predefinido
Rigidez	Baja (Fácil de cambiar)	Alta (Inflexible)	Media (Fácil de escalar)
Principio del Mínimo Privilegio (PoLP)	Requiere disciplina del usuario	Es inherente al modelo	Es implementado por el administrador
Uso Típico	PCs personales, archivos de usuario	Entornos militares, alta seguridad	Entornos Corporativos/Empresariales

[1] Principle of Least Privilege, o Principio de Mínimo Privilegio (Ver Autenticación)